

ICDFA Security Policy Manual

Principles of Information Security Governance

Field	Details
Full Name	MERCY RACHAEL AJAYI
Registration Number	C11/26/CGRCE/17219
Cohort / Batch	CGRCE Cohort 11
Course Title	Information Security Governance
Date Submitted	18th September, 2026
Document Owner	Head of Information Security (CISO)
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

Document control

Field	Entry
Document title	ICDFA Security Policy Manual
Document owner	Head of Information Security (CISO)
Approval authority	ICDFA Governing Board
Version	1.0
Effective date	1 October 2026, subject to Governing Board approval
Review date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

Distribution and acknowledgement

This manual applies to everyone who works for, studies at, or provides services to ICDFA. Each person must read the policies that apply to their role and sign an acknowledgement confirming they have read them. Human Resources keeps the signed acknowledgements for staff and the Registry keeps them for students.

Contents

- Section 1: Introduction and how to read this manual
- Section 2: Policy governance framework
- Section 3: The eight security policies
- Section 4: Framework and control mapping matrix
- Section 5: Implementation, communication and exception management plan
- Section 6: Policy effectiveness and management metrics
- Section 7: References

Section 1: Introduction and how to read this manual

ICDFA has grown significantly over the past few years. It now has academic systems, cloud platforms, digital laboratories, and a wider range of staff, students and partners using its resources. With this growth, relying on people to simply know what to do or making security decisions informally is no longer enough. There needs to be a clear structure that explains what is required, who is responsible, and how security requirements are maintained.

As the appointed Information Security Policy Adviser, my task is to translate ICDFA's governance objectives into policies, procedures and controls that can be understood and followed in practice. This section therefore focuses on the governance framework that supports the security policy manual. It explains the difference between policies, standards, procedures and guidelines, shows how they fit into a hierarchy, outlines the policy lifecycle, and assigns responsibilities to the relevant stakeholders.

The aim is to have a framework that is clear enough to guide day-to-day decisions and structured enough to support monitoring, review and accountability.

1.1 How to read this manual

- Must and shall mean a compulsory requirement. Not following them is a policy breach.
- Should means a strong recommendation. Anyone who does not follow a "should" statement needs to be able to explain why.
- May and can indicate an option or a capability, not a requirement.
- Each policy in Section 3 uses the same eleven-part structure, so once you have read one policy, you know where to find things in the others.
- Where the manual refers to a law or standard, the full citation is in Section 7.

1.2 Who this manual applies to

- All ICDFA employees, including management, academic staff and support staff.
- All students and learners, on campus or using ICDFA platforms remotely.
- Contractors, consultants, visiting examiners and other third parties who use ICDFA systems, data or premises.

Section 2: Task 1: Policy governance framework

2.1 Policy, Standard, Procedure and Guideline

A policy is the top-level document. It states management's position and intent, and it answers what needs to be done and why it matters. A standard sits just below a policy and makes its requirements more specific. It gives the mandatory requirements that show what the policy should look like in practice.

A procedure provides the step-by-step instructions for carrying out a task under a policy or standard. It is mandatory and should be clear enough for someone with the right skills to follow without having to ask what to do next. A guideline is different from the other three because it is not mandatory. It provides recommended practice for situations that a policy or standard does not directly cover, giving people a sensible approach to follow rather than a strict rule (ICDFA GRC102 Course Slides, 2026, Slide 3).

2.2 Policy Hierarchy

The security documents at ICDFA should follow a clear hierarchy. The Enterprise Information Security Policy provides the overall direction, while the documents below it provide more specific requirements and instructions.

Level	Document	Purpose
1	Enterprise Policy. For example, Enterprise Information Security Policy)	Sets the overall information security direction and authority for ICDFA.
2	Topic Specific Policies. For example, Access Control, Acceptable Use, Data Classification and Handling, Incident Response, etc.	Applies the overall direction to specific security areas.
3	Standards For example, Password and Authentication Standard, Data Labelling Standard, Cloud Configuration Baseline	Sets measurable minimum requirements.
4	Procedures For example, User Account Provisioning Procedure, Incident Reporting Procedure, Visitor Escort Procedure	Explains the steps for carrying out specific requirements.

5	Guidelines For example, Clean Desk Guideline, Secure Home Working Guideline	Provides practical recommendations where flexibility is appropriate.
---	--	--

The hierarchy also makes accountability clearer. A standard or procedure should be traceable to the policy it supports, and a lower-level document should not contradict a higher-level requirement. If a conflict is identified, it should be reported and resolved rather than ignored.

2.3 Policy Lifecycle

A policy should not be treated as a document that is written once and forgotten. It needs to move through a defined lifecycle so that it remains relevant as ICDFA's risks, technology and organisational needs change.

Stage	What Happens	Main responsibility
Drafting	A new policy or policy change is identified and a draft is prepared using risk assessments, audit findings and business need (ICDFA, 2026).	Policy owner
Consultation	The draft goes to the groups it affects, including Heads of Department, IT Services, Legal and Compliance, HR, and student representatives where relevant, so anything unworkable is flagged before approval.	Policy owner and stakeholders
Approval	The Management Committee reviews the draft, and the Governing Board formally approves it. The policy has no authority until this stage is complete.	Governing Board
Publication	The approved policy is stored in the central policy register, version controlled and dated. Only the register copy is authoritative.	Head of Information Security
Communication	The policy is actively explained to the people it affects and they	Head of Information Security, HR and Registry

	acknowledge that they have read it. Publishing a policy is not the same as communicating it.	
Implementation	The controls, procedures and supporting tools the policy requires are put in place.	IT Services and responsible implementers
Monitoring	Compliance and effectiveness are checked through audits, metrics and user feedback.	Information Security and GRC function
Exception Management	Requests to deviate from a requirement are risk assessed, approved or rejected, time-limited and logged in the Exception Register.	Head of Information Security
Review	The policy is reviewed at least annually, or earlier if a major incident, legal change, audit finding or significant organisational change triggers it.	Policy owner
Revision	Approved changes produce a new version, recorded in the version history and communicated to affected users.	Policy owner and Governing Board
Retirement	A policy no longer needed is marked superseded, removed from the active register and archived, with a record of when and why.	Head of Information Security

This lifecycle helps prevent policies from becoming outdated. It also gives ICDFa a clear process for dealing with changes instead of making informal adjustments whenever an issue comes up.

2.4 Stakeholder Responsibilities

Clear responsibilities are necessary because security governance becomes difficult to enforce when everyone assumes someone else is responsible. Each stakeholder should therefore have a defined role in the policy lifecycle.

Stakeholders	Responsibility
Governing Board	Authorises the policy programme, approves and retires policies, receives reports on policy performance and holds management accountable for information security.
Management Committee	Reviews policy drafts before Board approval, provides management support and approves exceptions within its authority.
Head of Information Security (CISO) and Policy Adviser	Owns the policy manual and policy register, coordinates the policy lifecycle, maintains the Exception Register and reports security metrics to management.
Policy Owners (one per policy)	Draft, consult on, review and revise their assigned policy, keep it accurate and current, and answer questions about how it applies.
Heads of Department and Unit Leads	Ensure that staff understand and follow the policies that apply to their areas and escalate requirements that may not be practical.
IT Services and system administrators	Implements the technical controls required by the policies and provides information needed for monitoring and reporting.
Legal and Compliance	Reviews policies against applicable legal, regulatory and contractual requirements.
Human Resources	Supports staff awareness, collects acknowledgements and handles disciplinary processes where necessary.
Registry	Manages student acknowledgements and supports communication of student-facing requirements.
Internal Audit or external auditors engaged by the Board	Independently tests whether policies are being followed and whether the controls work, and reports findings to the Board.
Staff, students, instructors and third parties	Read, acknowledge and follow the policies that apply to their role, and report security events and policy problems. Third parties also meet the security requirements in their agreements.

2.5 Why This Framework Supports Effective Governance

This framework gives ICDFa a more organised way of managing information security. The hierarchy shows how the different documents relate to each other, while the lifecycle ensures that policies have owners, review dates and a proper process for updating them.

The exception process is also important because there may be situations where a requirement cannot reasonably be followed. Instead of allowing people to create their own workarounds, the

issue can be formally assessed, approved where appropriate and recorded. This gives ICDFA better visibility of its risks.

Most importantly, assigning clear responsibilities makes it easier to know who should act when a policy needs to be implemented, reviewed or changed. This supports accountability and makes the security policy framework easier to monitor and audit. Overall, the framework provides the structure needed for the individual security policies in the rest of the manual.

Section 3: Task 2: ICDFA Security Policy Manual

The eight policies in this manual follow the same structure so that they are easy to understand, apply and review. Each policy can also be considered on its own without needing the rest of the manual to understand its main requirements.

3.1 Policy 1: Enterprise Information Security Policy

Document control

Field	Entry
Policy Title	Enterprise Information Security Policy
Policy Owner	Head of Information Security (CISO)
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.1.1 Purpose

This policy sets the overall direction for information security at ICDFA. It establishes the main principles that guide how ICDFA protects its information and information systems and provides the basis for the other security policies, standards and procedures in this manual.

The policy is intended to protect the confidentiality, integrity and availability of ICDFA's information while supporting its academic and operational activities.

3.1.2 Scope

This policy applies to all ICDFA staff, students, instructors, administrators, contractors and authorised third parties.

It covers all information and information systems owned, managed or used by ICDFA, including on-premises systems, cloud services, laboratories, classrooms, mobile devices, paper records and other information assets, wherever they are located.

3.1.3 Definitions

Term	Meaning
Confidentiality	Ensuring that information is only accessible to people who are authorised to access it.
Integrity	Ensuring that information remains accurate, complete and protected from unauthorised modification.
Availability	Ensuring that authorised users can access information and systems when they need them.
Information Asset	Any data, system, application, device, service or record that has value to ICDFA.
Security Event	An observable occurrence that may be relevant to information security, such as repeated failed login attempts or a suspicious email.
Security Incident	A security event that has caused or may cause harm to the confidentiality, integrity or availability of an information asset.
Third Party	Any external organisation or individual given access to ICDFA systems, data or premises under a contract or agreement.

3.1.4 Roles and Responsibilities

Roles	Responsibility
Governing Board	Approves this policy and receives assurance on its implementation and effectiveness.
Management Committee	Provides management direction, resources and support for the information security programme.
Head of Information Security (CISO)	Owens this policy, coordinates the security programme, oversees risk assessments and reports on information security performance.
Heads of Department	Ensure that applicable security requirements are understood and followed within their areas and nominate owners for relevant information assets.
IT / Security Function	Implements and maintains the technical and operational controls required by this policy.

All Users	Follow this policy and related security requirements and promptly report suspected security events or incidents.
-----------	--

3.1.5 Policy Statements

1. ICDFA shall protect the confidentiality, integrity and availability of its information and shall maintain a risk-based information security programme covering governance, technical controls, physical security and personnel security, aligned with the requirements of ISO/IEC 27001:2022 (ISO/IEC, 2022a).
2. ICDFA shall maintain an information security governance framework that supports its academic, administrative and digital activities.
3. This policy is the highest authority in the security policy hierarchy. No standard, procedure, guideline or local practice may contradict it, and every lower-level document must be traceable back to it.
4. Security controls shall be selected based on identified risks. ICDFA shall carry out a documented risk assessment at least annually and before major new systems, services or platforms are introduced.
5. Every information asset shall have a named owner who is responsible for its appropriate protection, classification, handling and disposal.
6. Access to information and systems shall be based on legitimate need and appropriate authorisation, following the principle of least privilege.
7. All staff and students shall complete required security awareness training during induction or enrolment and at least annually afterwards.
8. Anyone who becomes aware of a suspected security event or incident shall report it promptly through the approved reporting channel. Deliberately hiding a known incident is a breach of this policy.
9. Security requirements shall be considered from the beginning when new systems, cloud services, major processes or third-party arrangements are introduced, rather than being added only after implementation.
10. Third parties that access ICDFA information, systems or facilities shall be subject to appropriate security requirements through contracts or other formal agreements.
11. ICDFA shall comply with applicable legal, regulatory and contractual requirements relating to information security and data protection, including the Nigeria Data Protection Act 2023 and the Cybercrimes (Prohibition, Prevention, etc.) Act 2015, as amended (Federal Republic of Nigeria, 2015; Federal Republic of Nigeria, 2023).
12. No person shall intentionally bypass, disable or assist another person in bypassing a security control required by this manual.

3.1.6 Compliance and Framework Alignment

This policy aligns with ISO/IEC 27001:2022, which sets out the requirements for establishing, implementing, maintaining and continually improving an information security management system, particularly Clauses 5 to 7 on leadership, planning and support, and control A.5.1 on

policies for information security (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Govern function of NIST Cybersecurity Framework 2.0, which covers how an organisation establishes and monitors its cybersecurity risk strategy, expectations and policy (NIST, 2024). It also supports ICDDFA's duty under the Nigeria Data Protection Act 2023 to put appropriate technical and organisational measures in place for personal data.

3.1.7 Exceptions

1. Any request to deviate from this policy, or from the policies under it, must be made in writing using the Exception Request Form in writing, stating the requirement affected, the business or academic reason, the scope, the risk, the compensating controls proposed, the owner and the expiry date.
2. The Head of Information Security must risk assess the request before any decision is made.
3. An exception may only be granted where a compensating control brings the remaining risk down to an acceptable level.
4. All exceptions are time-limited, to a maximum of six months, and are recorded in the Exception Register. A fresh approval is needed after expiry.
5. No exception may set aside a legal or regulatory obligation.

3.1.8 Enforcement

Compliance with this policy is required as part of employment, enrolment and authorised third-party access to ICDDFA resources.

Depending on the nature and seriousness of a breach, non-compliance may result in additional training, removal of access, disciplinary action, suspension of academic privileges or contractual action. Serious or deliberate breaches may also be reported to the appropriate authorities where required by law.

Where a person reports their own mistake or security incident in good faith, this may be considered when determining the appropriate response.

3.1.9 Monitoring and Verification

The Head of Information Security shall monitor implementation using the metrics in Section 6 of this manual, and shall report them to the Information Security Committee. The measures used include:

- policy acknowledgement and attestation rates;
- percentage of policies reviewed on schedule;
- number of exceptions open, and number overdue;

- number of security incidents traced back to policy non compliance;
- completion rates for mandatory security awareness training.

Internal audit shall independently test compliance at least once a year and report its findings to the Governing Board. The exception and incident registers are reviewed regularly as part of this.

3.1.10 Review and Version Control

This policy shall be reviewed at least once a year by the policy owner. An earlier review may be carried out following a major security incident, significant change to ICDFA's systems or structure, a change in applicable law or regulation, or an audit finding that affects the policy.

All approved changes shall be recorded in the version history, and the current approved version shall be maintained in the official policy register.

3.1.11 Related Documents and References

- All other security policies in this manual
- ICDFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022
- ISO/IEC 27002:2022.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023.
- Cybercrimes (Prohibition, Prevention, etc.) Act 2015, as amended 2024.

3.2 Policy 2: Acceptable Use Policy (AUP)

Document Control

Field	Entry
Policy Title	Acceptable Use Policy (AUP)
Policy Owner	Head of IT Services
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.2.1 Purpose

This policy defines what is considered acceptable and unacceptable use of ICDFA devices, networks, accounts, applications and other digital resources. Its purpose is to make sure these resources are used responsibly and in a way that protects ICDFA, its users, information and systems from misuse.

3.2.2 Scope

This policy applies to all staff, students, instructors, administrators, contractors and authorised third parties who use ICDFA technology resources. It covers ICDFA devices, networks, accounts, email, learning platforms, laboratory systems, applications, cloud services and information stored or processed through these resources.

3.2.3 Definitions

Terms	Meaning
Acceptable Use	Use of ICDFA resources for authorised academic, research, administrative or operational purposes.
Unauthorised Use	Use that is outside a user's approved responsibilities or violates a law, policy, security requirement or another person's rights.
ICDFA Resources	Devices, networks, accounts, applications, storage, internet

	access and other digital services provided or authorised by ICDFA.
Incidental Personal Use	Limited personal use that does not interfere with ICDFA activities, consume excessive resources or violate any law or policy.

3.2.4 Roles and Responsibilities

Role	Responsibility
Head of IT Services	Owns this policy and maintains the technical systems and controls that support it.
Head of Information Security	Monitors compliance, investigates suspected misuse and manages security-related exceptions.
Heads of Department and Instructors	Communicate applicable requirements to their staff and students and encourage responsible use of ICDFA resources.
Human Resources and Registry	Track acknowledgements and support disciplinary or academic conduct action where it is needed.
All Users	Use ICDFA resources responsibly, protect their accounts and credentials, follow this policy and report suspected misuse.

3.2.5 Policy Statements

1. ICDFA resources shall be used mainly for authorised academic, research, administrative or operational purposes. Incidental personal use is permitted only where it does not interfere with the user's duties, consume significant resources, or breach any law or policy.
2. Each user is personally responsible for the activity on their own account. Accounts, passwords and authentication tokens must not be shared with anyone, including friends, family or colleagues.
3. Users must not attempt to access systems, data or networks they are not authorised to access, or interfere with another user's account. Unauthorised access is both a policy breach and an offence under the Cybercrimes (Prohibition, Prevention, etc.) Act 2015 as amended (Federal Republic of Nigeria, 2015).
4. Users must not introduce malicious software, disable or bypass security controls, or tamper with configurations set by IT Services.
5. Users must not use ICDFA resources for anything unlawful, fraudulent, defamatory or pornographic, or for harassment, bullying or discrimination, or for anything else likely to create a serious security or reputational risk for ICDFA.

6. Users must not store ICDFA data in personal email accounts, personal cloud storage or other unapproved services. IT Services defines the approved storage locations.
7. Sensitive information must not be transferred using removable media or external services unless the transfer is authorised and the safeguards in the Data Classification and Handling Policy are in place.
8. Software may only be installed on ICDFA devices with approval from IT Services, and licensing terms must be respected.
9. Users must protect ICDFA devices and information when working away from ICDFA facilities.
10. Suspected phishing, malware, account compromise, lost devices or any other security concern must be reported immediately to IT Services under the Incident Response Policy.
11. ICDFA may monitor, filter and audit the use of its networks and systems as far as the law permits, in order to protect security and investigate incidents. Users should not expect privacy in their use of ICDFA resources, and any personal data seen during monitoring is handled under the Nigeria Data Protection Act 2023.
12. When someone leaves ICDFA, or a contract ends, all ICDFA assets must be returned and access must be removed as set out in the Access Control Policy.

3.2.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 control A.5.10 on acceptable use of information and other associated assets, supported by control A.5.9 on the inventory of assets, with further guidance in ISO/IEC 27002:2022 on access control and human-related security practices (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Govern and Protect functions of NIST Cybersecurity Framework 2.0, and supports Detect outcomes where monitoring identifies possible compromise (NIST, 2024). It also reflects the expectation of lawful use of computer systems set out in the Cybercrimes (Prohibition, Prevention, etc.) Act 2015.

3.2.7 Exceptions

An exception may be requested where a genuine academic or operational need cannot be met under the normal requirement, for example, a researcher who needs software that is not on the approved list. The request must be made in writing and approved before the activity starts. Exceptions are risk assessed, time limited and logged in the Exception Register. There is no exception route for anything unlawful.

3.2.8 Enforcement

Violations of this policy may result in additional training, withdrawal of access, disciplinary action, academic or conduct action, contractual consequences or referral to the appropriate authorities, depending on the seriousness of the breach.

3.2.9 Monitoring and Verification

IT Services shall review network and platform usage logs for signs of abuse, and the Head of Information Security shall review reports of misuse monthly. HR and the Registry track acknowledgement of this policy by every user. The measures reported to management are:

- policy acknowledgement rate;
- number of acceptable use violations reported;
- number of repeat violations by the same user or department;
- number of malware or phishing incidents linked to user behaviour;
- security awareness training completion rate.

3.2.10 Review and Version Control

This policy must be reviewed at least once a year. An earlier review is triggered by a serious misuse incident, the introduction of a major new platform, a significant change in the user population or threat conditions, or a change in Nigerian law affecting electronic communications or data protection. All versions are recorded in the policy register.

3.2.11 Related Documents and References

- Enterprise Information Security Policy, Access Control Policy, Data Classification and Handling Policy, Incident Response Policy and Mobile Device and Endpoint Security Policy (All other security policies in this manual).
- Password and Authentication Standard, to be issued as a Tier 3 document.
- IC DFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022
- ISO/IEC 27002:2022.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023
- Cybercrimes (Prohibition, Prevention, etc.) Act 2015, as amended.

3.3 Policy 3: Access Control Policy

Document control

Field	Entry
Policy Title	Access Control Policy
Policy Owner	Head of Information Security (CISO)
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.3.1 Purpose

This policy sets the requirements for managing access to ICDFA systems, applications, networks and information. Its purpose is to make sure users only have access to what they need for their responsibilities and that access is removed when it is no longer required.

3.3.2 Scope

This policy applies to all staff, students, instructors, contractors and authorised third parties with access to ICDFA resources. It covers user, administrator, service and privileged accounts, as well as ICDFA applications, networks, cloud services, laboratories and information systems.

3.3.3 Definitions

Term	Meaning
Authentication	The process of verifying that a user is who they claim to be.
Authorisation	The process of determining what an authenticated user is allowed to access or do.
Least Privilege	Giving a user only the access needed to perform an authorised responsibility.
Multi-Factor Authentication (MFA)	Using two or more different methods to verify a user's identity, such as a password and an authenticator app.

Privileged Access	Access that gives elevated permissions, such as the ability to manage systems, users or security settings.
Joiner, mover, leaver (JML)	The process of granting, changing and removing access when a person joins ICDFA, changes role, or leaves.

3.3.4 Roles and Responsibilities

Role	Responsibility
Head of Information Security	Owens this policy, monitors compliance and oversees access reviews.
IT Services	Creates, changes and disables accounts and maintains the systems used to manage access.
Managers and Heads of Department	Approve access based on the user's role or legitimate need and confirm that access is still required during reviews.
System and Data Owners	Approve access to the systems and information under their responsibility.
HR / Administration	Notifies the relevant teams when users join ICDFA, change roles or leave.
All Users	Protect their credentials and use only the access assigned to them.

3.3.5 Policy Statements

1. Access is denied by default. It must only be granted after the requester's identity is verified and after documented approval by their line manager and the relevant system or data owner, on the basis of least privilege and need to know.
2. Every person must have their own unique account, so that actions can be traced back to an individual. Shared accounts are prohibited unless the Head of Information Security has approved a documented exception with compensating controls, and any such account must be controlled and logged.
3. Multi-factor authentication is mandatory for remote access, for all administrative and privileged access, and for any system holding Confidential or Restricted data under the Data Classification and Handling Policy.
4. Credentials must meet the Password and Authentication Standard. Authentication information must be protected from disclosure, never shared between users, never written down or stored in an unapproved way, and never reused on personal services.

5. Privileged access must be granted through a separate privileged account, limited to named individuals, used only for tasks that genuinely need elevated rights rather than everyday work, logged, monitored and reviewed every quarter. Shared administrative passwords must not be used.
6. Access must be provisioned only after approval. When a person changes role, access that is no longer needed must be removed within five working days. When a person leaves ICDDFA, all access must be removed on or before their final day, or within 24 hours of notification where the departure is abrupt.
7. Accounts inactive for 60 days must be disabled, and removed after a further 30 days, unless the system owner has documented a reason, such as a student between semesters.
8. Access reviews must be carried out quarterly for privileged access and at least annually for everything else. Outcomes must be recorded, and any access that cannot be justified must be removed.
9. Third-party access must be limited to the contract period, monitored, and removed on completion. Contractors must use individual accounts and must not hold privileged access unless it is explicitly approved and logged.
10. Authentication events and access decisions for critical systems must be logged and kept for at least 12 months to support incident investigation and audit.

3.3.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 controls A.5.15 access control, A.5.16 identity management, A.5.17 authentication information, A.5.18 access rights, A.8.2 privileged access rights and A.8.5 secure authentication, with supporting guidance in ISO/IEC 27002:2022 (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Protect function of NIST Cybersecurity Framework 2.0, which places identity management, authentication and access control in that function (NIST, 2024). Controlling who can reach personal data also supports the security safeguard requirements of the Nigeria Data Protection Act 2023.

3.3.7 Exceptions

An exception may be requested where a legitimate academic or operational need cannot be met under the normal access requirements. The request shall be documented, risk assessed and approved by the Head of Information Security before the exception is implemented. Exceptions shall have defined controls and an expiry date and shall be recorded in the Exception Register.

3.3.8 Enforcement

Unauthorised access, credential sharing, deliberate bypass of access controls or retaining access when it is no longer required may result in withdrawal of access, additional training, disciplinary or academic action, contractual consequences or referral to the appropriate authorities, depending on the seriousness of the breach.

3.3.9 Monitoring and Verification

Access and authentication logs are reviewed periodically, and privileged account activity is monitored for unusual patterns. IT Services shall produce monthly reports on privileged, orphaned and dormant accounts. The Head of Information Security shall report the following to the Management Committee each quarter:

- percentage of scheduled access reviews completed on time;
- number of access exceptions open, and how many are overdue;
- number of orphaned, inactive or excessive accounts found;
- percentage of designated accounts using MFA;
- average time taken to remove access after a confirmed departure.

3.3.10 Review and Version Control

This policy must be reviewed at least once a year. An earlier review is triggered by any incident involving compromised credentials or unauthorised access, a major change to ICDFA's identity systems, organisational restructuring, or a change in access requirements. All versions are recorded in the policy register.

3.3.11 Related Documents and References

- All other security policies in this manual.
- Password and Authentication Standard.
- User Account Provisioning Procedure
- Leaver Access Removal Procedure
- ICDFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.5.15 to A.5.18, A.8.2 and A.8.5.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023.

3.4 Policy 4: Data Classification and Handling Policy

Document Control

Field	Entry
Policy Title	Data Classification and Handling Policy
Policy Owner	Data Protection Officer
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.4.1 Purpose

This policy provides a consistent way to classify ICDFA information based on its sensitivity and sets the basic requirements for how information should be accessed, stored, shared, retained and disposed of.

3.4.2 Scope

This policy applies to all data created, received, processed, stored or shared by or for ICDFA, in any format, digital or paper, on premises, on authorised devices or in the cloud. It applies to everyone who handles ICDFA data, including staff, instructors, students and third parties.

3.4.3 Classification Levels

ICDFA uses four information classification levels:

Level	Meaning and examples	Impact if disclosed without authorisation
Public	Information approved for public release, such as course information, published research and official announcements.	No material harm. Publication is intended.
Internal	Information intended for use within ICDFA, such as internal memos, timetables and routine administrative information.	Limited harm or embarrassment. Not meant to leave ICDFA.
Confidential	Information that could cause harm, privacy concerns or operational problems if disclosed without authorisation, such as student records, grades, staff personal data and contracts.	Significant harm to individuals or to ICDFA, and likely breach of the Nigeria Data Protection Act 2023.
Restricted	Highly sensitive information requiring stronger protection because unauthorised disclosure, alteration or loss could cause serious harm, such as examination papers before an examination, forensic investigation files and sensitive Board documents.	Severe harm to individuals, legal liability, or serious damage to ICDFA's operations and reputation.

Where the appropriate classification is unclear, the information shall be treated at the higher level until the information owner makes a decision.

3.4.4 Roles and Responsibilities

Role	Responsibility
Data Protection Officer	Owns this policy and provides guidance on data classification and personal data handling.
Information Owners	Determine the appropriate classification for information under their responsibility and make sure it is handled accordingly.
IT Services	Provides the technical safeguards needed to protect information based on its classification.
All Users	Classify information appropriately and handle it according to its classification level.

Records / Administration	Supports information retention and secure disposal requirements.
--------------------------	--

3.4.5 Policy Statements

1. Every information asset must be classified by its data owner, based on its sensitivity, any legal or contractual requirement, and the impact if it were compromised. Where the right level is unclear, the information must be treated at the higher level until the owner decides.
2. Documents and media at Confidential and Restricted level must be labelled with their classification when they are created, stored or shared.
3. Confidential and Restricted information must only be accessible to authorised users with a genuine need to know. Restricted information must be limited to named individuals, and examination papers must follow the additional handling rules the Registry issues before each examination period.
4. Confidential and Restricted data must be encrypted in transit and at rest using methods approved by IT Services, and stored only in approved ICDFAs systems or approved cloud services.
5. Confidential and Restricted data must not be sent outside ICDFAs without the data owner's approval. Sharing with a third party requires a signed data sharing agreement or a contract carrying appropriate security terms.
6. Before sending Confidential or Restricted information, users must confirm the recipient is the right one and that the sharing method is approved.
7. Sending Confidential or Restricted data to personal email accounts, personal devices or unapproved cloud services is prohibited.
8. Physical records holding sensitive information must be protected from unauthorised viewing, loss or removal.
9. Personal data must only be processed where there is a lawful basis under the Nigeria Data Protection Act 2023, must be kept accurate and up to date, and must be limited to what is necessary for the purpose it was collected for (Federal Republic of Nigeria, 2023).
10. Information must be kept only for as long as there is a legitimate operational, academic, legal or contractual need. Retention periods are held in the ICDFAs retention schedule maintained by the Registry with Legal and Compliance.
11. Information at the end of its retention period must be disposed of securely: paper by cross-cut shredding or certified destruction, and digital media by certified wiping or physical destruction. A disposal record must be kept for Restricted items.
12. Any suspected loss or unauthorised disclosure of Confidential or Restricted information must be reported immediately under the Incident Response Policy.

3.4.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 controls A.5.12 classification of information, A.5.13 labelling of information, A.5.14 information transfer, A.5.33 protection of records and A.5.34 privacy and protection of personally identifiable information, with detailed guidance in ISO/IEC 27002:2022 (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Identify function of NIST Cybersecurity Framework 2.0 for asset management, and to the Protect function for data security (NIST, 2024). It gives practical effect to ICDDFA's duties as a data controller under the Nigeria Data Protection Act 2023, including the duty of care and the security of personal data, which the Nigeria Data Protection Commission oversees. The GDPR applies only where ICDDFA processes the personal data of individuals located in the European Union.

3.4.7 Exceptions

An exception may be requested where a legitimate academic or operational need cannot be met under the normal data handling requirements. The request shall be documented, risk assessed and approved by the Data Protection Officer or relevant information owner before the activity takes place. Any approved exception shall have appropriate safeguards and a defined expiry date. No exception shall remove rights or protections required by applicable data protection law.

3.4.8 Enforcement

Mishandling information is enforced under the same ladder as the Enterprise Information Security Policy, from corrective action and restriction of access through to disciplinary or contractual action. Because a data breach can harm real people and break the law, careless handling of Confidential or Restricted information is treated as a serious matter even where there was no bad intent. Where personal data is involved, the breach may also have to be reported to the Nigeria Data Protection Commission.

3.4.9 Monitoring and Verification

The Data Protection Officer shall review data handling practices each quarter, including disposal records and sharing approvals, and IT Services shall monitor approved storage locations for unclassified or mislabelled sensitive data and report findings monthly. The measures reported to management are:

- percentage of information assets with a classification assigned;
- percentage of sampled records handled correctly for their level;
- number of data handling incidents;
- number of overdue retention or disposal actions;
- percentage of relevant users completing data protection training.

3.4.10 Review and Version Control

This policy must be reviewed at least once a year. An earlier review is triggered by a confirmed data breach, a change to the Nigeria Data Protection Act or its regulations, a major change in how ICDDFA processes data, or a change to the classification levels themselves. All versions are recorded in the policy register.

3.4.11 Related Documents and References

- All other security policies in this manual
- Data Labelling Standard (Tier 3) and Media Disposal Procedure (Tier 4).
- ICDDFA retention schedule, maintained by the Registry.
- ICDDFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.5.12, A.5.13, A.5.14, A.5.33 and A.5.34.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023 and guidance issued by the Nigeria Data Protection Commission.

3.5 Policy 5: Incident Response Policy

Document control

Field	Entry
Policy Title	Incident Response Policy
Policy Owner	Head of Information Security (CISO)
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.5.1 Purpose

This policy provides a consistent approach for identifying, reporting, assessing, responding to and learning from information security incidents. It is intended to reduce the impact of incidents, support recovery and ensure that important lessons are used to improve security controls and procedures.

3.5.2 Scope

This policy applies to suspected or confirmed security incidents affecting ICDFA information, systems, networks, cloud services, laboratories, devices, facilities or third parties handling ICDFA information. It applies to incidents discovered by staff, students, monitoring tools or third parties.

3.5.3 Definitions

Term	Meaning
Security Incident	An event that has compromised or may compromise the confidentiality, integrity or availability of ICDFA information or systems, or has violated a security requirement.
Security Event	An observable occurrence that may require assessment to determine whether it is a

	security incident.
Breach	A confirmed incident involving unauthorised access to, or loss of, information.
Severity 1 (Critical)	An active compromise of critical systems, confirmed leakage of Confidential or Restricted information, ransomware or major loss of a critical service such as the learning platform.
Severity 2 (Major)	A confirmed malware infection affecting multiple devices, targeted phishing involving credential loss or significant disruption to a key service.
Severity 3 (Minor)	An isolated event with limited impact, such as a blocked phishing attempt or loss of a non-sensitive device.
Incident Response Team (IRT)	The group responsible for coordinating the response to significant incidents, including the Incident Commander, Technical Lead, Communications Lead and Scribe.
Evidence	Information that may help determine what happened, how it happened and what impact the incident had.

3.5.4 Roles and Responsibilities

Role	Responsibilities
Head of Information Security (CISO)	Owens this policy, maintains the incident response plan and oversees the response process for significant incidents.
Incident Commander	Leads the response, makes escalation decisions and coordinates containment, recovery and closure.
Technical Lead / IT Services	Carries out technical assessment, containment, investigation and recovery, while preserving relevant evidence.
Communications Lead	Controls internal and external communication about significant incidents and coordinates required notifications.
Management Committee	Receives escalation of critical incidents and makes major business, legal or reputational decisions.

All Users	Report suspected incidents promptly and avoid actions that could destroy evidence or make the situation worse.
Legal / Compliance Support	Provides advice on legal, regulatory, contractual and notification requirements where necessary.
Data Protection Officer, with Legal and Compliance	Advises on notification duties and coordinates any report to the Nigeria Data Protection Commission.

3.5.5 Policy Statements

Anyone who suspects a security event or incident must report it to IT Services as soon as they notice it, and no later than two hours after discovery, through the reporting channels IT Services publishes. Reportable events include suspected phishing, malware, unauthorised access, lost or stolen devices, accidental disclosure and suspicious system activity.

1. Users must not delete evidence, restart affected systems, attempt their own investigation, or talk about the incident publicly before reporting it.
2. The Head of Information Security must assess every report, assign a severity level and open an incident record within one working day. Severity 1 incidents must be escalated to the Management Committee within four hours of confirmation.
3. The Incident Response Team must be activated for all Severity 1 and Severity 2 incidents. The Incident Commander owns containment and recovery decisions, and no system may be rebuilt or wiped until evidence needs have been confirmed.
4. Evidence must be preserved following forensic good practice, which matters especially for an academy that teaches digital forensics. This includes preserving logs, taking forensic images where needed, and keeping a chain of custody record for anything that might support disciplinary or legal proceedings, in line with ISO/IEC 27001:2022 control A.5.28 on collection of evidence (ISO/IEC, 2022a; ISO/IEC, 2022b).
5. Response activities must follow the sequence of containment, eradication where appropriate, recovery, and post-incident review.
6. Where an incident involves a personal data breach likely to create a risk to individuals, the Data Protection Officer must notify the Nigeria Data Protection Commission within 72 hours as required by the Nigeria Data Protection Act 2023, and must notify the affected data subjects where the Act requires it (Federal Republic of Nigeria, 2023).
7. All external communication, including media and social media statements, must go through the Communications Lead. Staff and students must not post about an incident while it is still open.
8. Where a cybercrime is suspected, such as unauthorised access, fraud or ransomware, the Head of Information Security must advise the Management Committee on reporting it to law enforcement under the Cybercrimes (Prohibition, Prevention, etc.) Act 2015 as amended.
9. A post-incident review must be completed within ten working days of closing every Severity 1 and Severity 2 incident, identifying the root cause, what worked, what failed, and corrective actions with named owners and deadlines.

10. Corrective actions must be tracked through to completion, and recurring root causes must be reported to the Management Committee and fed back into policy and control improvements.
11. The incident response plan must be exercised at least once a year through a tabletop or simulated exercise, and the results must feed into policy and procedure updates.

3.5.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 controls A.5.24 to A.5.28 on incident management planning, event assessment, response, learning from incidents and collection of evidence, together with A.6.8 on information security event reporting, with supporting guidance in ISO/IEC 27002:2022 (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Detect function of NIST Cybersecurity Framework 2.0 for event assessment, and to the Respond and Recover functions for incident management, communication and restoration (NIST, 2024). It also meets the breach notification duties in the Nigeria Data Protection Act 2023 and supports cooperation with law enforcement under the Cybercrimes Act.

3.5.7 Exceptions

During an active Severity 1 incident, the Incident Commander may temporarily depart from standing procedures where following them would cause greater harm, for example, delaying containment to preserve evidence. Any deviation must be recorded in the incident log, approved by the Head of Information Security, and examined in the post-incident review. Standing exceptions to this policy follow the formal exception process set out in Section 3.5.6.

3.5.8 Enforcement

Failure to report a known or suspected incident, deliberate concealment, destruction of evidence or unauthorised disclosure of incident information may be treated as a breach of this policy and may result in disciplinary, academic, contractual or legal consequences. Users who report incidents promptly and in good faith shall not be penalised simply because they were involved in causing the incident.

3.5.9 Monitoring and Verification

The Head of Information Security shall produce a monthly incident summary for the Management Committee and the Information Security Committee. Incident trends also feed the annual risk assessment and policy reviews. The measures reported are:

- number of incidents by month and by severity;
- average time from discovery to reporting;
- average time from reporting to containment for significant incidents;
- percentage of incidents with a completed post incident review;

- number of open corrective actions, and number of repeat incidents sharing the same root cause.

3.5.10 Review and Version Control

This policy must be reviewed at least once a year, within thirty days after any Severity 1 incident, and after any change to reporting duties in Nigerian law, any significant technology change, or any exercise that exposes a major weakness. All versions are recorded in the policy register.

3.5.11 Related Documents and References

- All other security policies in this manual
- Security Incident Reporting Procedure
- Forensic Evidence Handling Procedure
- IC DFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.5.24 to A.5.28 and A.6.8.
- NIST Cybersecurity Framework 2.0, Detect, Respond and Recover functions.
- Nigeria Data Protection Act 2023
- Cybercrimes (Prohibition, Prevention, etc.) Act 2015 as amended.

3.6 Policy 6: Mobile Device and Endpoint Security Policy

Document control

Field	Entry
Policy Title	Mobile Device and Endpoint Security Policy
Policy Owner	Head of IT Services
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.6.1 Purpose

This policy sets the minimum security requirements for devices used to access ICDFA resources. It is intended to ensure that ICDFA-owned devices and authorised personal devices have an acceptable level of protection before accessing ICDFA systems or information.

3.6.2 Scope

This policy applies to ICDFA-owned laptops, desktops, laboratory computers, tablets, smartphones and other endpoints, as well as authorised personal devices used to access ICDFA resources. It applies to staff, instructors, students and authorised third parties using these devices.

3.6.3 Definitions

Term	Meaning
Endpoint	Any laptop, desktop, tablet, smartphone or similar device used to access ICDFA systems, networks or information.
Managed Device	A device enrolled in ICDFA's device management and monitoring systems.
BYOD	Bring Your Own Device, meaning a personally owned

	device authorised to access ICDFA resources.
Endpoint Protection	Security measures such as antivirus or endpoint detection and response tools used to protect devices from malware and other threats.

3.6.4 Roles and Responsibility

Roles	Responsibilities
Head of IT Services	Owns this policy and oversees the endpoint management arrangements that support it.
IT Services	Maintains, updates and monitors managed devices and supports the BYOD approval process.
Heads of Department / Laboratory Supervisors	Ensure that devices under their responsibility are accounted for and meet the requirements of this policy.
Device Users	Keep devices updated and secure, follow the required security controls and report loss, theft or compromise promptly.
Information Owners	Identify any additional security requirements where sensitive ICDFA information is accessed or stored on endpoints.

3.6.5 Policy Statements

All ICDFA-owned endpoints must be managed, meaning enrolled in device management, recorded in the asset inventory, and assigned to a named user or custodian.

1. Endpoints must run a supported operating system and receive updates automatically. Critical security patches must be applied within 14 days of release, and any device that cannot be patched must be disconnected from ICDFA networks.
2. ICDFA-managed endpoint protection must be installed on every endpoint that accesses ICDFA resources, and users must not disable it.
3. Full disk encryption is mandatory on all laptops and on any device that stores Confidential or Restricted data. Screen lock with authentication must activate after no more than five minutes of inactivity, so an unattended device cannot be used by someone else.
4. Personal devices may only access ICDFA resources with written approval under the BYOD process. An approved BYOD device must have screen lock, current updates,

device encryption where the platform supports it, and must allow ICDFA to remotely remove ICDFA data or wipe the device if it is lost or the user leaves.

5. Jailbroken or rooted devices must not access ICDFA resources.
6. Confidential or Restricted information must not be stored locally on a personal device unless that use has been authorised and the safeguards in the Data Classification and Handling Policy are in place.
7. Remote access to ICDFA systems must use approved authentication and connection methods, including multi-factor authentication as required by the Access Control Policy.
8. Removable media such as USB drives and external disks must not be used to carry Confidential or Restricted data unless the media is encrypted and the data owner has approved the transfer.
9. Shared laboratory and classroom machines must run restricted configurations, with user data saved to network locations rather than local disks, and must be wiped or reimaged at the end of each academic session or on a schedule set by IT Services.
10. Users must not disable, bypass or tamper with security controls on any endpoint, including approved personal devices.
11. Loss or theft of any device holding or able to access ICDFA information must be reported to IT Services within 24 hours so that access can be revoked and a remote wipe applied. Any device with credible evidence of compromise must be removed from access until it is cleared.

3.6.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 control A.8.1 on user endpoint devices, A.7.10 on storage media and A.7.14 on secure disposal or reuse of equipment, with supporting configuration and access guidance in ISO/IEC 27002:2022 (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Protect function of NIST Cybersecurity Framework 2.0, particularly platform security and device management, and to the Detect function through endpoint monitoring (NIST, 2024). Controlling personal data held on devices also supports the Nigeria Data Protection Act 2023.

3.6.7 Exceptions

An exception may be approved for a specialised academic, research or operational device that genuinely cannot meet a technical requirement, for example, a forensics workstation that must run an unsupported operating system. The request must be made in writing, risk assessed by IT Services, and approved with compensating controls such as network isolation and an expiry date of no more than six months.

3.6.8 Enforcement

Devices that do not meet this policy may be blocked from ICDFA networks until they are brought into compliance. Deliberately disabling required controls, using an unauthorised device for sensitive access, or repeatedly ignoring endpoint requirements is handled under the standard enforcement ladder for the relevant user group.

3.6.9 Monitoring and Verification

IT Services shall produce a monthly endpoint compliance report, with non-compliant devices flagged automatically where the device management platform allows it. The measures reported are:

- percentage of managed endpoints meeting the required security configuration;
- patch and update compliance rate;
- percentage of authorised devices with endpoint protection enabled and encryption in place;
- number of unmanaged devices found on the network;
- number of lost or stolen devices reported;
- number of endpoints blocked for non-compliance.

3.6.10 Review and Version Control

This policy shall be reviewed annually and earlier where necessary, including after a significant endpoint-related incident, a major change in endpoint technology or a change in the devices used within ICDFA.

3.6.11 Related Documents and References

- All other security policies in this manual
- BYOD Approval Procedure and Lost Device Procedure
- ICDFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.8.1, A.7.10 and A.7.14.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023

3.7 Policy 7: Cloud Security Policy

Document control

Field	Entry
Policy Title	Cloud Security Policy
Policy Owner	Head of IT Services
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.7.1 Purpose

This policy sets the requirements for selecting, approving, configuring and using cloud services at ICDFA. It is intended to ensure that ICDFA information remains protected while making clear what security responsibilities belong to ICDFA and what responsibilities belong to the cloud service provider.

3.7.2 Scope

This policy applies to cloud services used for ICDFA purposes, including learning platforms, cloud storage, productivity applications, hosting and Software as a Service (SaaS) platforms. It applies to staff, instructors, students and authorised third parties who use these services to access, store or process ICDFA information.

3.7.3 Definitions

Term	Meaning
Cloud Service	A technology service provided through a cloud environment rather than being hosted entirely on local ICDFA infrastructure.
Approved Cloud Service	A cloud service that has been assessed, approved and recorded for ICDFA use.
Shadow IT	A cloud service used for ICDFA work without the required

	approval or security assessment.
Shared Responsibility	The division of security responsibilities between ICDDFA and the cloud service provider, depending on the service being used.
Cloud configuration	The security and operational settings that control how a cloud service behaves.

3.7.4 Roles and Responsibilities

Role	Responsibility
Cloud Services Manager	Owns this policy, maintains the Cloud Services Register, and manages the provider relationships.
Head of Information Security	Reviews security risks and ensures appropriate security controls are considered before and during cloud use.
Data Protection Officer	Reviews personal data processing, privacy requirements and applicable data transfer considerations.
Service Owners	Manage the approved cloud services under their responsibility, including accounts, access and information stored within them.
Procurement and management	Make sure contracts carry the right security, privacy and supplier requirements.
Users	Use only approved services and follow the access and data handling rules.

3.7.5 Policy Statements

1. ICDDFA data must only be processed in cloud services listed in the Cloud Services Register. Using unapproved services for ICDDFA data, known as shadow IT, is prohibited, and sensitive information must never be placed in personal cloud accounts.
2. Before a service is approved, the Cloud Services Manager must complete a risk assessment covering the provider's security, availability, supplier risk, contract terms, data location, the sensitivity of the data involved, and exit arrangements. The Data Protection Officer must confirm the data protection terms meet the Nigeria Data Protection Act 2023.

3. Contracts and service agreements must set out security, privacy, availability, incident reporting and data handling responsibilities before any ICDDFA data is stored with the provider.
4. ICDDFA keeps responsibility for its own identity and access management, data classification and user activity in every cloud service, no matter what the provider operates. This split must be documented for each service at the point of approval.
5. Access must use ICDDFA-managed accounts with single sign-on where the service supports it. Multi-factor authentication is mandatory for all administrative access and for any service holding Confidential or Restricted data, in line with the Access Control Policy.
6. Administrative privileges must be limited to named authorised personnel and reviewed quarterly.
7. Cloud configurations must follow the Cloud Configuration Baseline. Public sharing must be off by default, storage buckets and containers must not be exposed publicly, and changes to critical settings must go through change control and be logged.
8. Logging and monitoring must be enabled for approved services holding Internal or higher data, with logs kept for at least 12 months and available for incident investigation.
9. Where personal data is transferred outside Nigeria, the transfer must meet the cross-border provisions of the Nigeria Data Protection Act 2023, and the Data Protection Officer must approve the transfer mechanism before the data moves (Federal Republic of Nigeria, 2023).
10. Each approved service must be reviewed at least annually to confirm it is still appropriate and secure, and immediately if the provider reports a significant breach or changes its terms in a way that affects ICDDFA data.
11. Every approved service must have a documented exit plan explaining how ICDDFA would retrieve its data and leave the service, including formats and deadlines.

3.7.6 Compliance and Framework Alignment

This policy implements ISO/IEC 27001:2022 control A.5.23 on information security for the use of cloud services and A.5.19 on information security in supplier relationships, with supporting guidance in ISO/IEC 27002:2022 (ISO/IEC, 2022a; ISO/IEC, 2022b). It maps to the Govern function of NIST Cybersecurity Framework 2.0 for third-party risk governance, Identify for risk assessment and asset understanding, and Protect for configuration and data security, and NIST states that the framework applies to cloud environments as much as to on-premises ones (NIST, 2024). It also gives effect to the Nigeria Data Protection Act 2023 where personal data is processed by a provider or held on infrastructure outside Nigeria.

3.7.7 Exceptions

Where a legitimate academic or operational need requires the use of a cloud service that has not been approved, the request shall be assessed before the service is used. The exception shall include a documented reason, risk assessment, appropriate compensating controls and a defined review or expiry date.

3.7.8 Enforcement

Use of unapproved cloud services for IC DFA information, deliberate misconfiguration or unauthorised sharing of information may result in access restrictions, corrective action or disciplinary, academic or contractual consequences, depending on the circumstances.

3.7.9 Monitoring and Verification

The Cloud Services Manager shall run quarterly configuration checks against the baseline to catch configuration drift, and IT Services shall monitor for unauthorised cloud use through network egress review and report monthly. The measures reported are:

- percentage of cloud services in use that are formally approved;
- percentage of critical cloud services with a completed security review;
- percentage of privileged cloud accounts reviewed on schedule;
- number of open cloud security exceptions;
- number of cloud incidents caused by configuration or access weaknesses.

3.7.10 Review and Version Control

This policy shall be reviewed annually and earlier where necessary, including after a significant cloud security incident, a major change in cloud services, a change in data protection requirements or a significant change in the terms of an approved provider.

3.7.11 Related Documents and References

- All other security policies in this manual
- Cloud Configuration Baseline (Tier 3) and Cloud Service Approval Procedure (Tier 4).
- IC DFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.5.19 and A.5.23.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023.

3.8 Policy 8: Physical Security Policy

Document control

Field	Entry
Policy Title	Physical Security Policy
Policy Owner	Facilities Manager
Approval Authority	ICDFA Governing Board
Version	1.0
Effective Date	1 October 2026, subject to Governing Board approval
Review Date	1 October 2027, or earlier if a review trigger occurs
Classification	Internal

3.8.1 Purpose

This policy sets the requirements for protecting ICDFA facilities, equipment, information and physical media from unauthorised access, theft, damage and other physical security threats. It ensures that physical weaknesses do not undermine the security of ICDFA's information and systems.

3.8.2 Scope

This policy applies to ICDFA offices, classrooms, laboratories, server and network rooms, storage areas and other facilities used for ICDFA activities. It also covers physical assets such as computers, servers, network equipment, access cards, keys, storage media and paper records, as well as visitors to ICDFA premises.

3.8.3 Definitions

Terms	Meaning
Physical Asset	A tangible resource such as a computer, server, network device, document, storage media or other equipment.
Restricted Area	An area where access is limited to authorised persons because it contains sensitive assets or requires additional security.

Visitor	A person who is not a regular authorised user of the relevant ICDDFA facility or area.
Zone	An area of the premises with a defined access level: public, general, restricted or high security.

3.8.4 Roles and Responsibilities

Roles	Responsibilities
Facilities Manager	Owns this policy and manages physical access, visitor arrangements and facility controls.
Head of Information Security	Provides security guidance and monitors physical security alongside information security controls.
Laboratory supervisors and Heads of Department	Control access to their areas and equipment, keep equipment registers current, and make sure their people know the local requirements.
Security personnel and reception	Support entry control, visitor registration and response to physical security incidents.
All staff and students	Protect equipment, keys, access cards and physical information and report suspicious activity or security faults.

3.8.5 Policy Statements

ICDDFA premises must be divided into zones: public areas open to visitors, general areas for staff and students, restricted areas such as laboratories and records rooms, and high security areas such as server rooms and examination stores. Access rights must match the zone.

1. Entry to general, restricted and high security zones must be controlled by access card or an approved equivalent. Access cards and keys are personal, must never be shared or left unsecured, and any loss must be reported within 24 hours so the card can be revoked.
2. Tailgating into a controlled zone is prohibited. Staff and students must politely challenge anyone they do not recognise in a restricted area and refer unresolved cases to security.
3. All visitors must sign in at reception, wear a visible visitor badge, and be escorted at all times in restricted and high security areas. Visitor records and access logs for restricted areas must be kept for at least 12 months.
4. Server rooms, network rooms and examination stores must be locked at all times, opened only for named authorised staff, and every entry must be logged. Critical rooms

must also have environmental safeguards appropriate to the risk, such as fire detection, cooling and power protection.

5. Laboratory and IT equipment must be recorded in an equipment register, signed in and out where it is portable, and must not leave campus without written approval from the laboratory supervisor or asset owner.
6. Equipment and media holding Confidential or Restricted data must be stored securely when not in use, and portable devices and sensitive documents must not be left unattended where an unauthorised person could reach them.
7. Confidential documents must not be left on desks or in printers, must be kept in locked storage, and must be destroyed in locked shredding consoles rather than general waste. Equipment and media leaving ICDDFA must be securely wiped or destroyed first.
8. Where CCTV is installed, it must cover entrances and high value areas only, must be signposted, and footage must be kept for no more than 30 days unless it is needed for an investigation. Footage is Confidential information under the Data Classification and Handling Policy and access to it is restricted.
9. Access rights to restricted areas must be reviewed on the same cycle as system access under the Access Control Policy, and keys, badges and media must be returned when a person leaves ICDDFA as part of the leaver process.
10. Physical security incidents and faults, including theft, unauthorised entry, lost credentials, broken locks and faulty card readers, must be reported the same day and treated as a priority for repair, and incidents must also be logged under the Incident Response Policy.

3.8.6 Compliance and Framework Alignment

This policy supports the organisation's information security requirements and is aligned with relevant security frameworks and legal requirements.

The policy supports ISO/IEC 27001:2022 and ISO/IEC 27002:2022 physical security controls, including controls relating to physical security perimeters, physical entry controls, securing offices and facilities, and physical security monitoring.

It also supports the NIST Cybersecurity Framework (CSF) 2.0, particularly the Govern and Protect functions, by establishing responsibilities and controls for protecting facilities, equipment and other physical assets.

Where physical security activities involve personal information, such as CCTV recordings, visitor records or access logs, the organisation shall handle such information in accordance with the Nigeria Data Protection Act 2023 and other applicable requirements.

3.8.7 Exceptions

Exceptions to this policy shall be limited, documented and based on a valid business or operational need. Any exception request shall clearly state the requirement being waived, the reason for the request, the expected duration, the risks involved and any proposed compensating controls.

The relevant policy owner shall review the request and assess whether the exception creates additional security or operational risks. Where necessary, the Information Security function shall carry out a further risk assessment before approval.

Approved exceptions shall be recorded in the organisation's exception register, including the reason for the exception, responsible owner, approval, compensating controls and expiry date.

Exceptions shall be reviewed before their expiry date. An exception may only be renewed where the business need still exists and the associated risks remain acceptable. Emergency exceptions shall also be documented and reviewed after the emergency has been addressed.

3.8.8 Enforcement

Breaches of this policy, such as lending an access card, bypassing a lock, or bringing an unauthorised person into a restricted area, are handled under the standard enforcement ladder, and access may be withdrawn. Theft, deliberate damage and unauthorised entry are referred to campus security and, where appropriate, to law enforcement.

3.8.9 Monitoring and Verification

The Facilities Manager shall carry out monthly walkthrough checks of physical controls and report the results to the Head of Information Security. Access logs and, where installed, CCTV footage for high security areas shall be sampled quarterly for anomalies. The measures reported are:

- percentage of restricted areas reviewed for access control on schedule;
- number of physical security incidents;
- visitor record completion rate;
- number of lost or unreturned keys and access cards;
- percentage of physical security findings remediated.

3.8.10 Review and Version Control

This policy must be reviewed at least once a year. An earlier review is triggered by a physical security breach, a significant change to the premises or a relocation, a change in the sensitivity of the activities carried out in a facility, or a change to the legal requirements around CCTV. All versions are recorded in the policy register.

3.8.11 Related Documents and References

- All other security policies in this manual
- Visitor Escort Procedure, Equipment Register Procedure and Media Disposal Procedure (Tier 4).
- ICDFA GRC102 Week 2 course material.
- ISO/IEC 27001:2022 and ISO/IEC 27002:2022, controls A.7.1 to A.7.4.
- NIST Cybersecurity Framework 2.0.
- Nigeria Data Protection Act 2023.

Section 4: Task 3: Framework and Control Mapping Matrix

This matrix shows how selected requirements from the eight IC DFA policies connect to recognised information security frameworks. The requirements are mapped to the most relevant ISO/IEC 27001:2022 control area and NIST Cybersecurity Framework 2.0 function. Nigerian legal requirements are only included where they are directly relevant.

GDPR is not treated as a general requirement because IC DFA is a Nigerian institution. It would become relevant if IC DFA processes the personal data of individuals in the European Union in circumstances where GDPR applies.

Policy and requirement	Business or Risk Objective	ISO/IEC 27001:2022 Alignment	NIST CSF 2.0 Function	Legal / Regulatory Note
Enterprise Information Security Policy: maintain an information security governance framework	Provide clear direction and accountability for information security across IC DFA	Information security policies; roles and responsibilities; continual improvement	Govern	Supports good governance. No specific legal requirement claimed
Enterprise Information Security Policy: annual risk assessment, and again before major new systems go live	Make sure effort and money go to the risks that actually matter	Clause 6 planning and risk treatment	Identify	No specific legal requirement claimed.
Enterprise Information Security Policy: mandatory security awareness training	Reduce human error, which sits behind most incidents	A.6.3 awareness, education and training	Govern	No specific legal requirement claimed.
Acceptable Use Policy: no unauthorised access to systems or information	Prevent misuse of IC DFA systems and unauthorised access to information.	A.5.10 Acceptable use of information and other associated assets	Govern / Protect	Unauthorised access may be relevant under the Cybercrimes Act 2015, as amended.
Access Control Policy: least privilege	Limit access to only what a user needs and reduce the impact of compromised accounts.	A.5.15 Access control; A.8.2 Privileged access rights	Protect	Supports the security of personal data under the NDPA 2023 where personal data is involved.
Access Control Policy:	Reduce the risk of	A.5.17	Protect	Supports appropriate

authentication and MFA for privileged and remote access	account takeover and unauthorised access.	Authentication information; A.8.5 Secure authentication		security safeguards for personal data where applicable.
Access Control Policy: periodic access review	Identify and remove unnecessary or excessive access before it can be misused.	A.5.18 Access rights	Govern / Protect	Supports accountability for access to personal data where applicable.
Incident Response: prompt reporting, triage and severity assignment	Detect and contain incidents quickly, before the damage spreads	A.5.24 to A.5.26 incident management planning, assessment and response; A.6.8 event reporting	Detect and Respond	Where a personal data breach is involved, NDPA 2023 breach notification requirements may apply.
Incident Response: forensic evidence preservation with chain of custody	Evidence survives for disciplinary action, law enforcement and learning	A.5.28 collection of evidence	Respond	May support cooperation with relevant authorities where an incident has legal implications.
Data Classification and Handling Policy: classify information according to sensitivity	Make sure sensitive information receives the level of protection it needs.	A.5.12 Classification of information; A.5.13 Labelling of information	Identify / Protect	Relevant to the NDPA 2023 where personal data is processed.
Data Classification and Handling Policy: retention schedule with certified secure disposal	Data is not kept longer than needed, and is not recoverable once disposed of	A.5.33 protection of records; A.7.14 secure disposal or reuse; A.8.10 information deletion	Protect	Supports the storage limitation principle under the NDPA 2023.
Mobile Device and Endpoint Security Policy: security updates and endpoint protection	Reduce exposure to known vulnerabilities and protect devices connecting to ICDA systems.	A.8.1 User endpoint devices; A.8.8 Management of technical vulnerabilities	Protect	No specific legal requirement claimed.
Cloud Security Policy: use only approved cloud services and	Reduce risks from unapproved cloud services, poor	A.5.19 Supplier relationships; A.5.23 Information	Govern, Identify and Protect	NDPA 2023 may apply where cloud providers process

review providers	configuration and third-party providers.	security for use of cloud services		personal data, including relevant transfer requirements.
Physical Security Policy: restrict access to sensitive areas	Prevent theft, tampering and unauthorised physical access to equipment and information.	A.7.1 Physical security perimeters; A.7.2 Physical entry; A.7.3 Securing offices, rooms and facilities	Protect	No specific legal requirement claimed.
Policy governance: annual and trigger-based policy review	Keep security requirements relevant as risks, technology and organisational activities change.	Clause 10 improvement; management review and policy governance	Govern	Supports ongoing compliance and governance.
Policy governance: exception requests with risk assessment and compensating controls	Stop people bypassing requirements informally and invisibly	Clause 6 risk treatment; A.5.1 policies for information security	Govern	An approved exception does not remove a legal or regulatory obligation.

The mapping is kept at the control-theme level because the purpose is to show how the policies connect to recognised frameworks, rather than to present a full ISO/IEC 27001 compliance or certification assessment.

Section 5: Task 4: Implementation, Communication and Exception Management

5.1 Implementation Approach

I would use a phased approach instead of introducing all eight policies at the same time. This gives users enough time to understand the requirements and gives ICDDFA the opportunity to identify and correct issues before moving to the next phase.

Phase	Policies/Activities	Reason
Phase 1	Enterprise Information Security, Access Control and Acceptable Use	These establish the main security rules, user responsibilities and access foundations for the other policies.
Phase 2	Data Classification and Handling and Incident Response	Classification helps users understand how information should be protected, while Incident Response provides a clear process for dealing with security incidents.
Phase 3	Endpoint Security and Cloud Security	These address the main technology environments used to access, process and store ICDDFA information.
Phase 4	Physical Security and supporting standards/procedures	This strengthens the physical security environment and provides the supporting documents needed to apply the policies properly.
Phase 5	Monitoring, audit, feedback and improvement	This helps ICDDFA measure implementation, identify problems and make necessary improvements.

This phased approach also makes implementation more manageable because the organisation can focus on one group of requirements before moving to the next.

5.2 Communication Plan

Different groups need different information depending on their roles. The communication should therefore explain what each group is expected to do and where they can get help or more information.

Audience	What they need to know	Communication method	Owner	Timing
Staff (academic and support)	Policies affecting daily work, access, data handling and incident reporting	Email, staff meetings, short awareness sessions and policy repository	HR with Heads of Department	Before and during implementation, with periodic refreshers
Management and Governing Board	Why the manual matters, what it commits them to, and the metrics they will receive	Board briefing and signed foreword at launch	Head of Information Security	Before implementation and during reviews
Instructors	How the policies affect teaching, access, student data and classroom technology	Briefing sessions, email and role-specific training	Academic Dean	Before implementation and when requirements change
Administrators	Access management, records, data handling, governance responsibilities and escalation	Management briefings and role-specific training	HR and IT Services	Before implementation and during reviews
Student	Acceptable use, account security, safe handling of information and reporting channels	Orientation, student portal, email and short awareness materials	Registry with instructors	At onboarding and periodically
Third parties (contractors, partners, vendors)	Contractual security requirements, access responsibilities and reporting expectations	Contract terms, onboarding information and supplier communication	Procurement with Legal	Before access is granted and during contract review

5.3 Training and Awareness Plan

Training should be based on the responsibilities of each role rather than giving everyone the same level of training.

Audience	Training focus	Format	Frequency
All staff and students	Passwords and MFA, phishing awareness, acceptable use, basic data handling, and how to report an incident	Short online module plus acknowledgement	At induction or enrolment, then annually
Instructors	Handling examination materials, classroom and laboratory device use, and student data	Faculty workshop using real scenarios	Annually, and before each examination period
Administrators and Registry staff	Personal data handling, access approvals, retention and disposal	Workshop plus a desk reference	Annually
IT Services and laboratory technicians	Access management, technical standards and configuration baselines, logging, cloud security, incident response and evidence handling	Hands-on sessions and a tabletop exercise	Every Six Months
Heads of Department and policy owners	Their ownership duties, approving access, handling exceptions, escalation and the review cycle	Briefing session	Annually
Management and Board	How to read the security metrics, when to escalate, and their governance duties	Short executive briefing	Annually

Training completion should also be recorded so that ICDFa can confirm who has completed the required training and identify areas where additional awareness may be needed.

5.4 Leadership Support

Senior management should visibly support the policy programme rather than leaving it to the IT or security team alone. This can include formally approving the policies, communicating why they are important, providing the resources needed for implementation and holding responsible departments accountable.

The course material identifies visible leadership support as an important part of successful policy implementation.

5.5 Supporting Tools

The policies will be easier to follow if users have simple tools that support the requirements. These would include:

- Policy acknowledgement form
- Security awareness training record
- Access request and approval form
- Periodic access review checklist
- Security incident report form
- Policy exception request form and central exception register
- Cloud service security review checklist
- Data classification and handling guide
- Endpoint compliance checklist
- Policy review and version history log

These tools help turn the policies from written requirements into things that can actually be used during normal work.

5.6 Formal Exception Process

There may be situations where a policy requirement cannot immediately be followed because of a legitimate business or technical reason. Instead of allowing people to create informal workarounds, ICDFA should use a formal exception process.

1. The responsible user or business unit submits an exception request explaining why the requirement cannot currently be met.
2. The policy owner confirms the requirement affected and checks whether there is another compliant option.
3. The security or risk function assesses the security and compliance impact of granting the exception.

4. Compensating controls are identified where the risk cannot be completely removed.
5. The authorised approval authority approves or rejects the request.
6. Approved exceptions are recorded centrally with the reason, owner, risk level, compensating controls and expiry date.
7. The exception is monitored throughout the approved period.
8. Before expiry, the exception is reviewed and either closed, renewed with proper justification or replaced with a compliant solution.

The course material recommends risk assessment, compensating controls, formal approval, time-limited exceptions, central documentation and regular review as part of effective exception management.

5.7 Feedback and Continuous Improvement

Implementation should not end once the policies have been communicated and training has been completed. Users should have a simple way to report difficulties or areas that are unclear.

Feedback can be collected through short surveys, training sessions, incident reviews, audit findings and exception requests. If a requirement is repeatedly misunderstood or results in many exception requests, the policy owner should review whether the requirement is clear and practical.

This allows ICDFA to improve the policies over time instead of simply expecting users to work around requirements that may not be practical.

Section 6: Task 5: Policy effectiveness and Management metrics

Writing policies is not enough. ICDFa also needs a way to know whether the policies are being followed and whether they are helping to reduce security risks. The following metrics cover areas such as compliance, training, access control, incidents, exceptions, audits and technical security. These are based on the effectiveness measurement approach discussed in the course material.

Metric	Owner	Data Source	Frequency	Target / Threshold	Reporting Audience	Action if the threshold is missed
Policy acknowledgement rate	Policy Owner / HR	Acknowledgement records	Monthly during rollout, then quarterly	At least 95% within 30 days of joining or of publication	Management and Policy Owners	Reminder campaign, and escalate to any department below 90 per cent
Security awareness training completion rate	Security / HR	Training platform and attendance records	Monthly	At least 95% of required users	Management	Manager-level follow-up, catch-up sessions and a retraining mandate
Access review completion rate	IT / System Owners	Access review records	Quarterly	100% of scheduled reviews	IT and Management	Escalate to system owners, and freeze new access requests for overdue areas
Number and recurrence of policy exceptions	GRC / Policy Owners	Exception Register	Monthly	No expired exceptions and a downward trend in recurring exceptions	Management	Renew or close the exception, and review whether the underlying policy needs revising
Critical policy-related audit findings	GRC / Internal Audit	Audit reports	Quarterly	No overdue critical findings	Management	Assign a named executive owner and track weekly until closed
Incidents caused by policy non-compliance	Security / Incident Response	Incident records and root-cause reviews	Monthly	Downward trend	Management	Root cause review, targeted retraining, control strengthening or policy revision

Policies reviewed within the approved cycle	Policy Owners	Policy Register	Quarterly	100%	Management/ GRC	Name the owner, commit a new review date at the next meeting, and address any resourcing gap
Endpoint compliance rate	IT / Security	Endpoint management tools	Monthly	At least 95% of managed endpoints	IT and Management	Non compliant devices blocked from the network until they are fixed
Cloud security review completion	Cloud Owner / Security	Cloud service register and review records	Quarterly	100% of critical cloud services	Management	Remediate misconfigurations within 14 days and engage the provider where the fault is theirs
Data disposal verification	Data Protection Officer	Disposal records and sample checks	Quarterly	100 per cent of sampled disposals supported by evidence	Management	Reissue the disposal procedure and retrain the responsible unit.
Average incident reporting time	Incident Response Lead	Incident records	Monthly	Within ICDFA's defined internal reporting target	Security and Management	Review reporting barriers and improve awareness or reporting channels

These metrics should be considered together rather than separately. For example, if a particular policy keeps generating repeated exceptions, the issue may be that the requirement is difficult to apply in practice. In that case, ICDFA should review the policy and not simply assume that users are failing to comply. The same approach can be applied to incident trends, audit findings and training results to identify areas that need improvement.

References

Federal Republic of Nigeria (2015) *Cybercrimes (Prohibition, Prevention, etc.) Act, 2015*. Abuja: Federal Republic of Nigeria.

Federal Republic of Nigeria (2024) *Cybercrimes (Prohibition, Prevention, etc.) (Amendment) Act, 2024*. Abuja: Federal Republic of Nigeria.

Federal Republic of Nigeria (2023) *Nigeria Data Protection Act, 2023*. Abuja: Federal Republic of Nigeria.

International Cybersecurity and Digital Forensics Academy (ICDFA) (2026) *GRC102 Week 2 Course Material: Developing Security Policies and Procedures*. Lagos: International Cybersecurity and Digital Forensics Academy.

International Organization for Standardization (ISO) (2018) *ISO/IEC 27000:2018 Information technology. Security techniques. Information security management systems. Overview and vocabulary*. Geneva: ISO.

International Organization for Standardization (ISO) (2022a) *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection. Information security management systems. Requirements*. Geneva: ISO.

International Organization for Standardization (ISO) (2022b) *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection. Information security controls*. Geneva: ISO.

National Institute of Standards and Technology (NIST) (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. NIST CSWP 29. Gaithersburg, MD: National Institute of Standards and Technology.